IAM: OneLogin y permisos reales de la aplicación

2 de octubre de 2026

Implementación disponible

La aplicación exige OneLogin OIDC. La API SCIM Core 1 permite alta, consulta, actualización, suspensión y eliminación. El almacén comprueba cuenta activa y rol en cada operación, incluso si la sesión estaba abierta antes de un cambio. comprobar_scim.py verifica acceso anónimo rechazado y consulta con token correcto; no crea usuarios ni prueba el MFA por sí mismo.

1. Coordinar con TI

Recibir APP_BASE_URL y SCIM_TOKEN de la configuración local, mediante el canal privado. El secreto no se escribe en el plan, README, Issues ni evidencia. Crear el conector OIDC y el conector SCIM siguiendo la guía completa (04_IAM_OneLogin.pdf).

OIDC devuelve a APP_BASE_URL/auth/callback. SCIM recibe en APP_BASE_URL/scim/v1. Mantener la configuración del token endpoint compatible con el conector. Los parámetros Client ID, Client Secret y metadata URL los copia TI a .env; nunca se configuran dentro del JavaScript del navegador.

2. Crear perfiles

Perfil ficticio	title/lab_role	Permisos de aplicación
LAB-INGENIERO	mantenimiento	Consulta y contador de mantenimiento
LAB-ADMIN	admin	Consulta, mantenimiento, estado, registros y hub
LAB-AUDITOR	auditor	Consulta, registros y hub
LAB-SOC	soc	Consulta, registros y hub
Consulta	consulta	Consulta
Sin acceso	sin_acceso	Ninguna acción protegida

externalId debe contener el identificador de laboratorio que se usará en RFID y SOC. userName debe coincidir con el correo que entrega OneLogin en la identidad firmada. Una cuenta SOC no recibe administración por observar los registros. Frigate tiene sus propias cuentas de consulta; el enlace del hub no inicia sesión automáticamente en el NVR.

3. Comprobar SCIM

En el servidor TI, cargar .env en una terminal privada; ejecutar el verificador desde el clon:

```
set -a
source ~/lab-runtime/app/.env
set +a
python3 Areas/IAM/comprobar_scim.py --url https://REEMPLAZAR.trycloudflare.com
```

Resultado esperado: anonimo 401, autorizado 200 y correcto true. El token se obtiene del entorno y no aparece en la línea de comando. No usar HTTP ni URLs con credenciales.

4. Alta automática

1. RRHH entrega solicitud aprobada.
2. Crear el usuario OneLogin y configurar sus atributos.
3. Asignar el conector SCIM mediante la regla o mapping autorizado.
4. Confirmar el evento de aprovisionamiento y que la cuenta aparece en la aplicación, sin ejecutar un alta local manual.
5. Asignar el conector OIDC.
6. Registrar MFA y abrir una sesión nueva con desafío real.
7. Consultar y ejecutar mantenimiento con el ingeniero; guardar antes y después del contador.

5. Cambio y baja

Cambiar title a auditor desde OneLogin y confirmar SCIM_UPDATE. Mantener la sesión anterior abierta: mantenimiento debe responder 403. Suspender el usuario o retirar la aplicación según la política del conector y confirmar active false o SCIM_DELETE. Repetir con la sesión anterior y después con un inicio nuevo. Registrar tiempo de propagación y resultado efectivo.

Los tests HTTP usan una respuesta de proveedor simulada exclusivamente en pruebas para comprobar vínculo de identidad y permisos. El sistema que se despliega utiliza Authlib y OneLogin reales; no contiene un modo de login local.

Entrega

Matriz de roles, configuración sin secretos, resultado del verificador, evidencias de aprovisionamiento/MFA/cambio/baja y referencias del evento. Las cuentas de OneLogin no se han creado desde aquí porque requieren el tenant y sus permisos.